

TP1 – Clickjacking

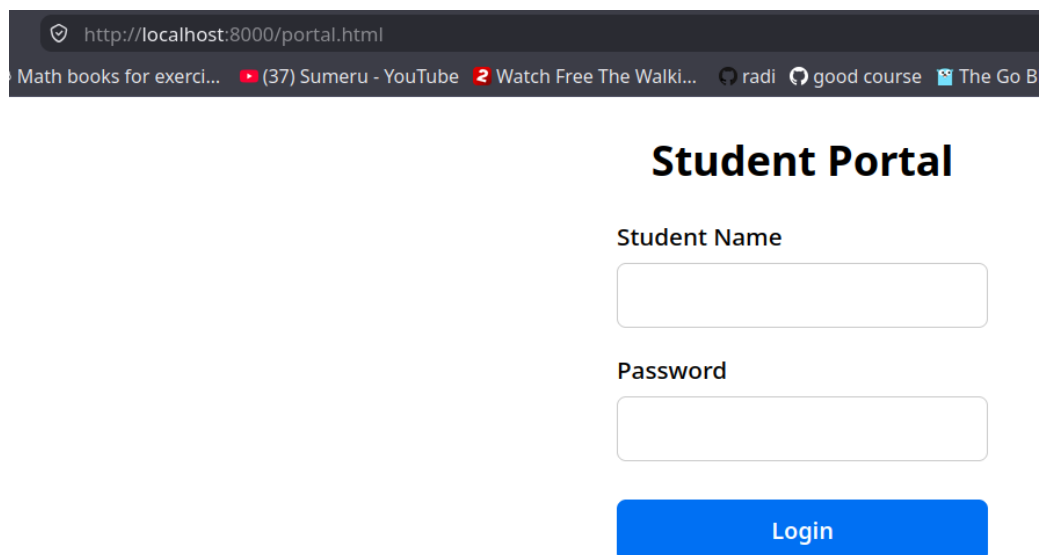
Oussama Yaqdane

September 15, 2026

1 Introduction

Clickjacking TP

2 Student Portal



http://localhost:8000/portal.html

Math books for exerci... (37) Sumeru - YouTube Watch Free The Walki... radi good course The Go B

Student Portal

Student Name

Password

Login

Figure 1: Student Portal

3 Decoy Game

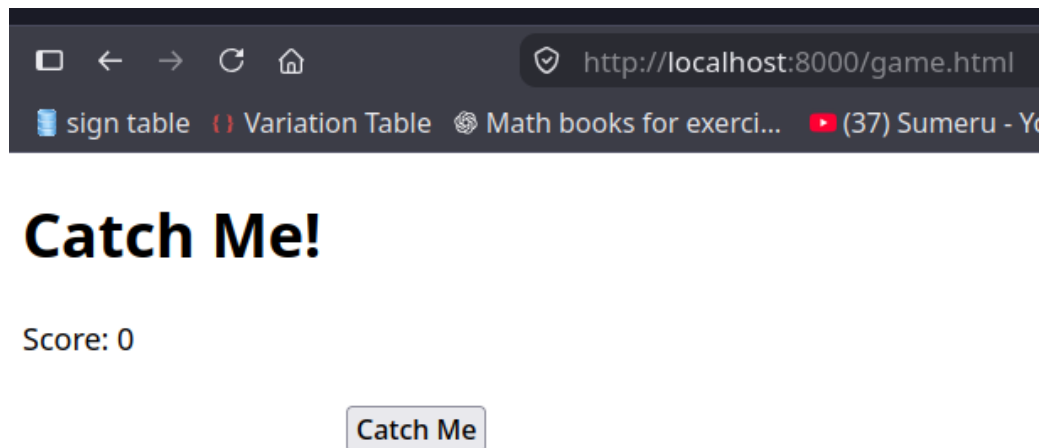


Figure 2: Decoy game

4 Embedding the Portal with an iframe

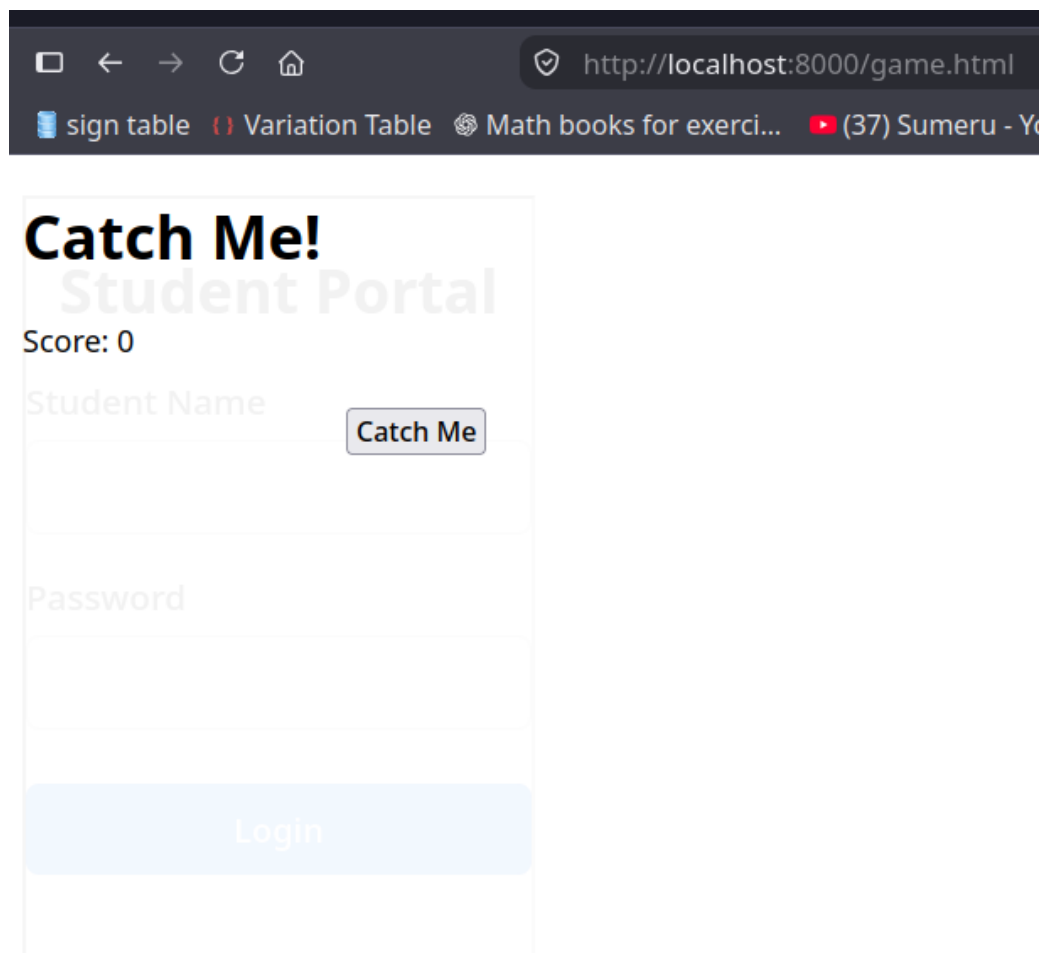


Figure 3: Student Portal embedded in the game

5 Hiding the iframe

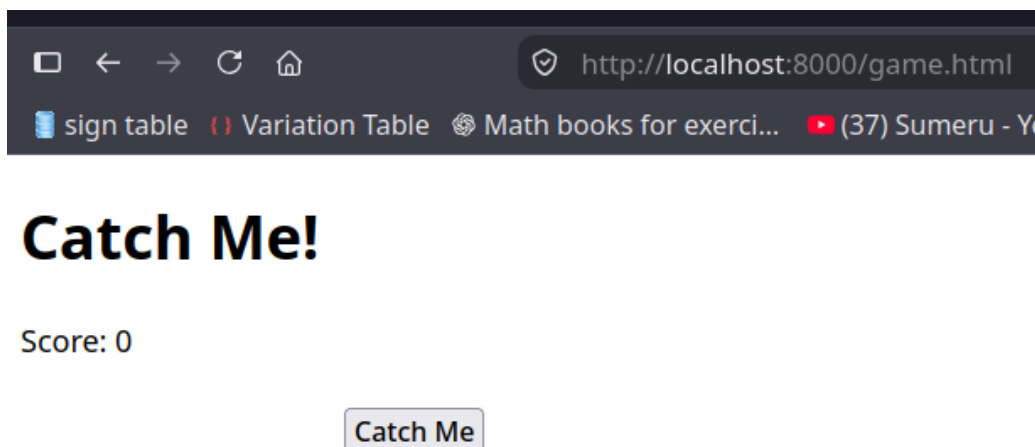


Figure 4: Hidden iframe

6 Clickjacking Attack

Pointer events is set to 'none' for the catch me button, so a click on it is counted as a click on the underlying Login button.

Catch Me!

Student Portal

Score: 3

Student Name

Password

Catch Me Login

Figure 5: Clickjacking setup

7 Defending Against Clickjacking

7.1 X-Frame-Options

X-Frame-Options is an HTTP header used to control if a page can be loaded inside an iframe. Using **DENY** blocks the page from being framed completely, while **SAMEORIGIN** only allows pages from the same origin to frame it.

7.2 Content Security Policy

CSP provides a more modern way to control this using the **frame-ancestors** directive. For example:

`Content-Security-Policy: frame-ancestors 'none';`

This means that the page cannot be embedded by any other page.

If we only want pages from the same origin to embed it, we can use:

`Content-Security-Policy: frame-ancestors 'self';`

For the Student Portal, I would use `frame-ancestors 'none'` because there is no reason for the login page to be inside another website.

If another trusted university application needs to embed the portal, its origin can be explicitly allowed in `frame-ancestors` instead of allowing every website.